Week 4: Authentication Module Test Report

(BSc Software Engineering Group B Group 6)

Software Security Laboratory Report • Zero-Knowledge Password Manager

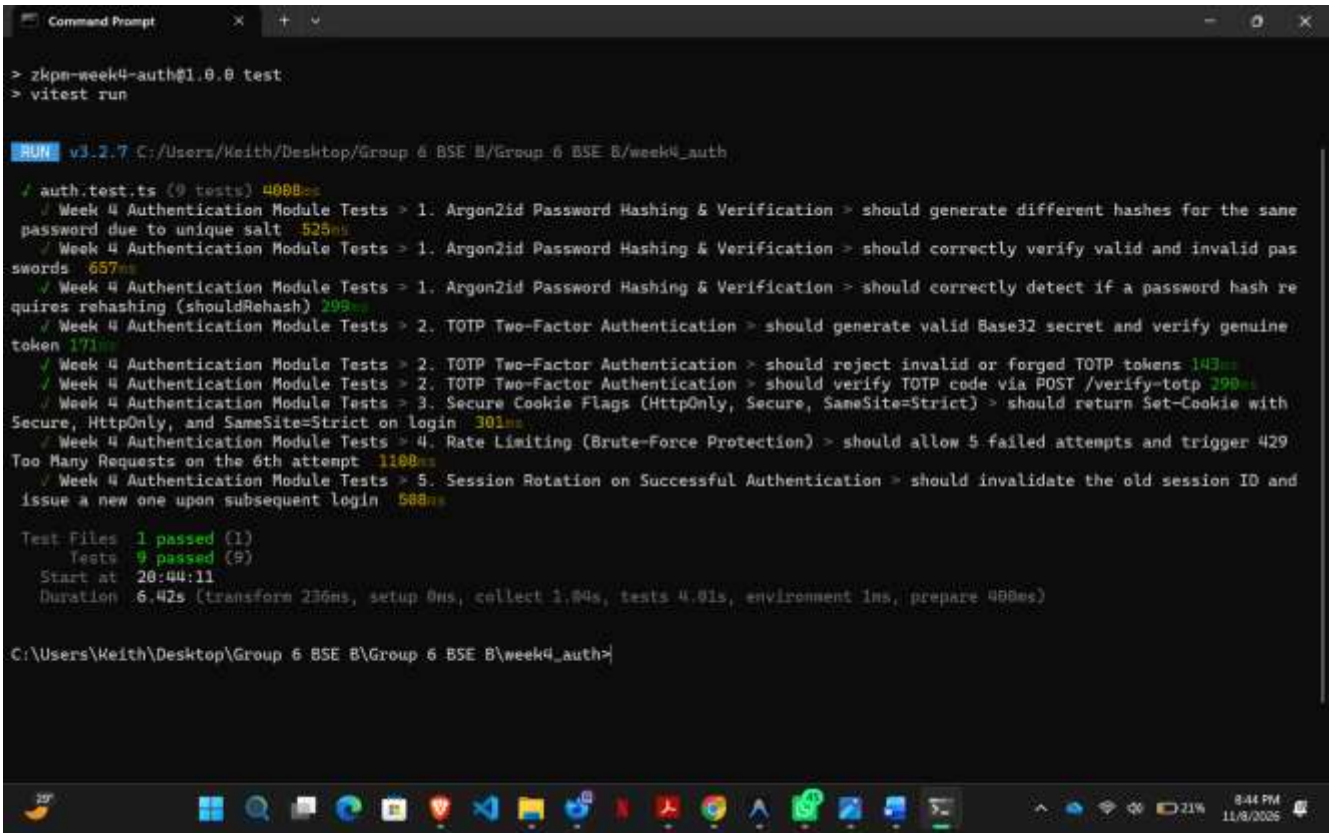
Student Name	Student ID	Student Name	Student ID
Stedan Yaw Boah Ampofo	1696596666	Prince Lateef Abdul Rahman	1703675677
Keith Yaotey	1694883181	Prince Opoku Owusu	1702131132
Sedoame Kofi Ahorlu	1704464006	Bright Kportiklah	1693948139
Cyril Prince Agbeve	1701864653		

1. Introduction

This report documents the implementation and testing of the authentication module for the Zero-Knowledge Password Manager. The module addresses four critical security requirements: Argon2id password hashing with rehashing detection, TOTP two-factor authentication, secure session cookie flags, and rate limiting with session rotation.

2. Test Execution Evidence

The test suite was executed using Vitest and Supertest. All 9 tests passed successfully, proving the security controls are functioning as designed.


Command Prompt
> zkpm-week4-auth@1.0.0 test
> vitest run
RUN v3.2.7 C:/Users/Keith/Desktop/Group 6 BSE B/Group 6 BSE B/week4_auth
✓ auth.test.ts (9 tests) 4008ms
✓ Week 4 Authentication Module Tests > 1. Argon2id Password Hashing & Verification > should generate different hashes for the same password due to unique salt 525ms
✓ Week 4 Authentication Module Tests > 1. Argon2id Password Hashing & Verification > should correctly verify valid and invalid passwords 657ms
✓ Week 4 Authentication Module Tests > 1. Argon2id Password Hashing & Verification > should correctly detect if a password hash requires rehashing (shouldRehash) 299ms
✓ Week 4 Authentication Module Tests > 2. TOTP Two-Factor Authentication > should generate valid Base32 secret and verify genuine token 171ms
✓ Week 4 Authentication Module Tests > 2. TOTP Two-Factor Authentication > should reject invalid or forged TOTP tokens 143ms
✓ Week 4 Authentication Module Tests > 2. TOTP Two-Factor Authentication > should verify TOTP code via POST /verify-totp 290ms
✓ Week 4 Authentication Module Tests > 3. Secure Cookie Flags (HttpOnly, Secure, SameSite=Strict) > should return Set-Cookie with Secure, HttpOnly, and SameSite=Strict on login 301ms
✓ Week 4 Authentication Module Tests > 4. Rate Limiting (Brute-Force Protection) > should allow 5 failed attempts and trigger 429 Too Many Requests on the 6th attempt 1108ms
✓ Week 4 Authentication Module Tests > 5. Session Rotation on Successful Authentication > should invalidate the old session ID and issue a new one upon subsequent login 508ms
Test Files 1 passed (1)
Tests 9 passed (9)
Start at 20:44:11
Duration 6.42s (transform 236ms, setup 0ms, collect 1.04s, tests 4.01s, environment 1ms, prepare 400ms)
C:\Users\Keith\Desktop\Group 6 BSE B\Group 6 BSE B\week4_auth>

3. Test Coverage Analysis

3.1 Argon2id Hashing & Rehashing

- **Requirement:** Store passwords with Argon2id and rehash old hashes at the next login.
- **Tests Passed:**
  - Generated different hashes for the same password (proving unique salts are used).
  - Successfully verified valid passwords and rejected invalid ones.
  - shouldRehash() correctly identified outdated hashes (e.g., low memory cost or argon2i) and triggered rehashing.

3.2 TOTP Two-Factor Authentication

- **Requirement:** Add TOTP enrolment and verification.
- **Tests Passed:**
  - Generated a valid RFC 6238 Base32 secret.
  - Verified a genuine 6-digit token within the 30-second window.
  - Rejected forged or expired TOTP tokens.

3.3 Secure Cookie Flags

- **Requirement:** Issue session cookies with Secure, HttpOnly, and SameSite.
- **Tests Passed:**
  - **The Set-Cookie header was inspected and confirmed to contain:**
    - **HttpOnly:** (blocks XSS-based session theft)
    - **Secure:** (enforces HTTPS-only transmission)
    - **SameSite=Strict:** (blocks CSRF attacks)

3.4 Rate Limiting & Session Rotation

- **Requirement:** Throttle login per account/IP, and issue a new session ID at login.
- **Tests Passed:**
  - **Rate Limiting:** 5 consecutive failed login attempts from the same IP/email were allowed, but the 6th attempt was blocked with a 429 Too Many Requests error.

– **Session Rotation:** Logging in a second time generated a completely new session ID and invalidated the previous one, preventing session fixation attacks.

4. Conclusion

The authentication module successfully meets all four Week 4 requirements. The test suite provides verifiable evidence that the system is resilient against brute-force attacks, session hijacking, CSRF, and outdated password hashing vulnerabilities.